

Test & Trial Guide — Cornell Deep · Identity Protection Platform

Purpose: walk through the project step by step and showcase every feature, with the seed-account table and where to get live OTP codes. After following this guide you will have tried: e-mail verification, the trusted device, the three scenarios (S1/S2/S3), cross-device approval, the full SOC dashboard, simulated attacks A/B/C, the school portal and RBAC, account recovery, and digital forensics.

1) Requirements & startup

- **Requirement:** Node.js **24 or newer** only — no other software or databases needed.
- **Steps:**

```
npm install      # install dependencies (once)
npm run db:reset # (optional) pristine database with seed data
npm start        # start the server
```

Open your browser at: **http://localhost:4000**

The terminal prints a banner listing the ready-made users with the Ethereum preview e-mail (when offline, e-mail messages are printed right there as plain text).

2) Seed accounts table

Full details from the database (display name, role, department, e-mail, phone):

Username	Password	Role	Display name	Department	E-mail
student1	Student@123	STUDENT	Sarah Chen	Computer Science	sarah.chen@campus.edu
student2	Student@123	STUDENT	Omar Farouk	Computer Science	omar.farouk@campus.edu

Username	Password	Role	Display name	Department	E-mail
teacher1	Teacher@123	TEACHER	Dr. Elena Roberts	Information Security	elena.roberts@campus.edu
teacher2	Teacher@123	TEACHER	Prof. Marcus Reid	Network Engineering	marcus.reid@campus.edu
admin	Admin@123	ADMINISTRATOR	Alex Morgan	IT Security Office	alex.morgan@campus.edu

Note: these accounts are **not** pre-marked as trusted — any ****new login from your device**** is evaluated by risk score (new device +30, new network +25).

Where do I find a live OTP code?

The login screen shows a **DEMO panel** that streams each account's current TOTP (refreshes every 30 seconds). Alternative: open <http://localhost:4000/api/identity/otps> in the browser to view the same codes as JSON.

3) Full step-by-step tour

Chapter 1 — Admin login & the SOC dashboard

1. On the login screen enter `admin` / `Admin@123` and pick scenario **3**.
2. Enter the OTP from the DEMO panel, then the extra e-mail code (or the terminal printout when offline).
3. The **SOC dashboard** opens with tabs: Overview, Audit, Sessions, Devices, Factors, Lists, Simulation.
4. Switch **tabs** and watch live counters (SSE streaming — any event appears instantly, no refresh).

Chapter 2 — Scenario 1 (password only) as a student

1. Log out, then log in as `student1` / `Student@123` with scenario **1**.
2. Because the context is low-risk → direct login.
3. In your personal Security Center see: trusted devices, sessions, activity, and your security posture score.

Chapter 3 — Scenarios 2/3 with an OTP step

1. Log in as `teacher1` / `Teacher@123` with scenario **2**.
2. The system prompts for an OTP code (scenario 2) — take it from the DEMO panel and complete.
3. Try scenario **3** and verify it requests **OTP + e-mail** together.
4. **Key insight:** the scenario is the manual request, but the adaptive risk score can add extra steps automatically.

Chapter 4 — Registering a new account & activating a trusted device

1. On the login screen press **Create account / سجل**.
2. Fill in: name, a valid-looking e-mail (e.g. `myname@gmail.com`), national ID, and a password ≥ 8 chars.
3. After creation, the terminal/response shows the **verification link with an Ethereum preview**.
4. Press "Create" then **Verify now in this browser** ← an "Email verified ✓" page.
5. **Result:** this browser is now a **trusted device** — log in with the same account and scenario 1 → direct login, no extra step.

Chapter 5 — Cross-Device Approval

1. Open the same project URL in an **Incognito window**.
2. Log in with the account you just registered, scenario **2**.
3. In the **trusted** browser an "Approve external login?" modal appears instantly (device, IP, reasons, risk score).
4. Press **Approve** to complete the login in the incognito window; or **Deny** to reject it.
5. Then try turning off the trusted device (or wait ~20 seconds) → the request automatically falls back to e-mail + OTP.

Chapter 6 — Simulated attacks (the showcase)

From the admin dashboard (SOC) → **Attack Simulation** tab:

- **Type A (Brute Force):** wrong password attempts → watch the risk score climb until logout.
- **Type B (Impossible Travel):** login from Riyadh then San Francisco → +40 → logout.
- **Type C (Credential Stuffer):** login from an IP on the blacklist → blocked.

Watch: the **live timeline** below, the score distribution in Overview, and the success/failure counters.

Chapter 7 — Blacklist / whitelist

1. In the **Blacklist** tab add any address such as `31.13.99.5`.
2. Any later login attempt from this address is rejected instantly, even with a correct password (+45).

Chapter 8 — School portal & RBAC (permission matrix)

- Log in as `student1` → **Portal** tab: only his courses, grades and attendance; class rosters or the user directory are **denied (403)**.
- Log in as `teacher1` → the portal shows only his courses and his class rosters.
- Log in as `admin` → the full portal + the **8×3 permission matrix** displayed for you.

Chapter 9 — Account recovery & MFA reset

1. From the **personal Security Center** choose recovery / MFA reset.
2. Follow `request → reset → validate`: verification code → rotate TOTP secret + new password → **10 single-use recovery codes**.
3. Log in afterwards with the new TOTP secret and note the operation recorded in the admin's log.

Chapter 10 — Digital forensics

1. From the admin dashboard open **Forensics**.
2. Search for a user (e.g. `student1`) → a fully **reconstructed timeline**.
3. Create a **case** with one click → evidence is captured automatically → export the evidence as **Markdown** for archiving.

Chapter 11 — Benchmark (performance comparison)

From the same tab view **Benchmark**: number of attempts per scenario (S1/S2/S3), average login time (from real `elapsed_ms`), and success counters — a visual comparison of the cost of extra verification.

Chapter 12 — Live streaming (two windows at once)

1. Leave the admin dashboard open on the **Overview** tab.
2. In another window log in (or run a simulated attack) → watch the event appear **instantly** in the first window.

Chapter 13 — Data resilience after restart (NFR)

1. Change some data (devices / sessions / cases / attacks).
2. Stop the server (`Ctrl+C`) then start it again.
3. Log in as admin and confirm all the data is still there (persistent SQLite storage).

Chapter 14 — Full automated testing (140 checks)

Stop the server first, then:

```
node scripts/reset-db.js      # pristine database
npm start                    # start the server
node scripts/smoke.js         # 17
node scripts/e2e-all.js      # 77
node scripts/ui-smoke.js      # 28
node scripts/restart-check.js # 18 (uses a separate port: 4001)
```

Expected: every script finishes with  and an "ALL PASS" report — **140 green in total**.

4) How to raise the risk score manually? (to test every level)

Factor you want to trigger	Do this	Result
F_TIME_ANOMALY (+15)	log in between 23:00 and 07:00	higher score, login needs an extra step
F_NEW_IP (+25)	log in from a different gateway / network	score increases
F_NEW_DEVICE (+30)	log in from a non-trusted browser/device (incognito)	score increases, OTP/approval required

Factor you want to trigger	Do this	Result
F_IMPOSSIBLE_TRAVEL (+40)	run the Type-B attack from the admin dashboard	risk ~95 and instant lockout
F_BLACKLISTED_IP (+45)	add your address to the blacklist then log in	instant block even with a correct password
F_CONSECUTIVE_FAILURE (+20×)	enter a wrong password twice in a row	automatic lockout after the second

Releasing the lockout: admin dashboard → Threat Factors → **Force unlock** for the user.

5) Feature checklist (tick while you try)

#	Feature	How to try	✓
1	Registration + real e-mail confirmation	Chapter 4	☐
2	Trusted device (1-year cookie)	Chapter 4 / api/me	☐
3	Scenario 1 (password only)	Chapter 2	☐
4	Scenario 2 (OTP)	Chapter 3	☐
5	Scenario 3 (OTP + e-mail)	Chapter 3	☐
6	Risk score & LOW/MEDIUM/HIGH bands	Chapters 4 / 2	☐
7	Cross-device approval (+ fallback)	Chapter 5	☐
8	SOC dashboard & live SSE streaming	Chapters 1 / 12	☐
9	Attacks A/B/C and live counters	Chapter 6	☐
10	Whitelist / blacklist	Chapter 7	☐
11	School portal RBAC (8×3) with 403 protection	Chapter 8	☐
12	Permission matrix for the admin	Chapter 8	☐
13	Recovery + 10 recovery codes	Chapter 9	☐
14	Digital forensics + cases + export	Chapter 10	☐
15	Benchmark (time comparison)	Chapter 11	☐
16	Data resilience after restart	Chapter 13	☐
17	Automated testing (140 green)	Chapter 14	☐

6) Attached visual evidence (Screenshots_EN.pdf + PNG)

15 screenshots attached in [ProjectDeliverables/08_لقطات الشاشة وأدلة الاختبار_08](#), all captured automatically from the running app in a real browser at **2160×1350** via `node scripts/capture-screenshots.js` (session and role are validated inside the script).

#	File	What it proves	Covers
1	01-login-light.png	Login screen, default Light theme + toggle	1
2	02-login-ocean.png	Same content in Ocean theme (different visual identity)	1
3	03-login-seed-accounts.png	Seed accounts + live Demo OTP code	2
4	04-register.png	Create account then verify e-mail	1
5	05-soc-overview.png	SOC dashboard: risk score, sessions, alerts	8
6	06-soc-audit-log.png	Live authentication log with risk factors and rationale	6, 9
7	07-soc-sessions.png	Active sessions: device, network, last activity	8
8	08-soc-devices.png	Devices + trust and block lists	10
9	09-soc-attack-simulation.png	Attacks A/B/C and their live impact on SOC	9
10	10-benchmark-scenarios.png	1/2/3 comparison: attempts, successes, time	15
11	11-forensics-timeline.png	Timeline and opening a case with evidence capture	14
12	12-student-security-center.png	Student Security Center + recovery path	13
13	13-portal-student.png	School portal: courses/grades/attendance (student role)	11
14	14-portal-teacher.png	Portal as teacher — data isolation (RBAC)	11, 12
15	15-app-ocean-theme.png	Ocean theme after login, kept between sessions	1

Regeneration: start the server then `node scripts/capture-screenshots.js` , then

`node scripts/export-screenshots-pdf.js` to refresh `Screenshots*.pdf` .

7) FAQ & common errors

Where is the OTP code? The DEMO panel on the login screen, or <http://localhost:4000/api/identity/otps> . The code refreshes every 30 seconds — if it expires, wait for the next one.

Why is the e-mail not arriving? The app uses Ethereum; use the preview link it shows. Offline, the message is printed in the terminal (`mail-degraded` mode).

Entered a wrong OTP? The account is not locked (lock is only for repeated password failures); just retry with a fresh code.

What do 401 vs 403 mean? 401 = no session / not logged in; 403 = authenticated but with insufficient rights.

Is this a real production platform? An educational/demonstration project simulating defense mechanisms; do not use it for sensitive data without a security review.